Wie sicher sind meine Daten in der Club-App?

Eine einfache Erklärung für alle Mitglieder des Köcheclub Werne – Handy, Datenbank, Zugang, Spiegelung und Sicherung. Stand 29.10.2026.

Das Wichtigste in 30 Sekunden

1. Dein Zugang ist persönlich

Du kommst nur mit deinem eigenen Link oder einem 6-stelligen Code in die App. Gespeichert wird davon nur ein „Fingerabdruck" – nie der Schlüssel selbst.

2. Ein Türsteher prüft alles

Jede Anfrage geht über den Club-Server. Er prüft jedes Mal: Wer bist du und darfst du das sehen? Direkt an die Datenbank kommt von außen niemand.

3. Du bestimmst, was andere sehen

Telefon, Adresse, Geburtstag, Online-Status und Dienstzeiten zeigst du nur, wenn du es willst. Heikle Schalter stehen ab Werk auf AUS.

4. Unterwegs immer verschlüsselt

Zwischen Handy und Server läuft alles verschlüsselt (wie beim Online-Banking). Auch gespeichert sind die Daten verschlüsselt.

5. Fünf Orte, die auf deine Daten aufpassen

Original, Spiegel und drei getrennte Sicherungen – die Sicherungen verschlüsselt und gegen Ändern gesperrt. Jeden Tag wird geprüft, ob die Wiederherstellung klappt.

6. Kostenlos und ohne Werbung

Die Datenbank steht in London, Sicherungen zusätzlich in Frankfurt – alles auf kostenlosen Tarifen. Keine Werbung, kein Verkauf von Daten, keine Weitergabe an Fremde.

7. Regelmäßig von KI überprüft

Unser Admin lässt die gesamte App regelmäßig mit künstlicher Intelligenz (Claude Code und ChatGPT) auf Sicherheit, Sicherheitslücken, Bedienung und Logik prüfen – mehr auf Seite 9.

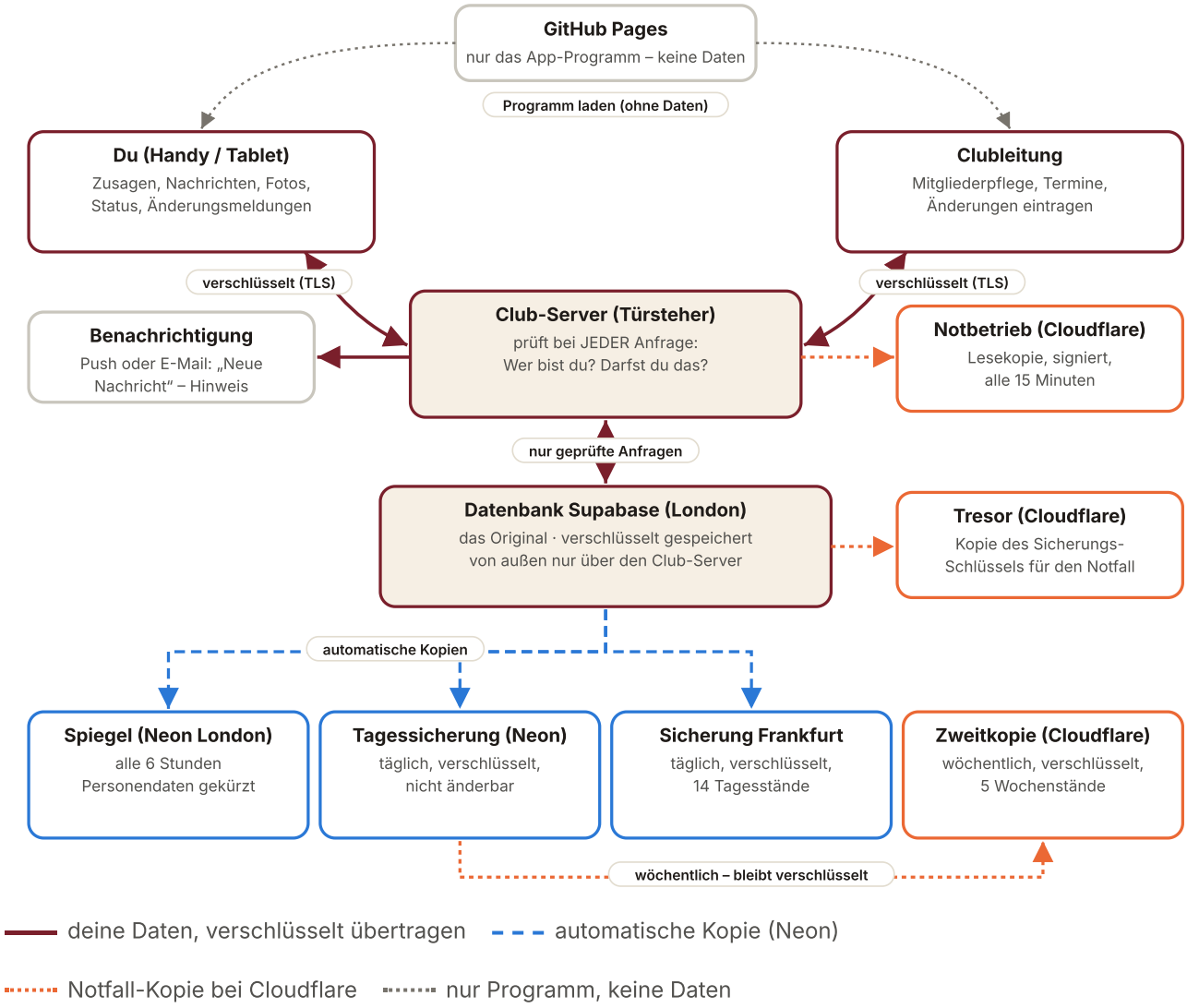
273	6 h	1 min	0
Tabellen in jeder Tagessicherung – alle beim Test geprüft	höchstens so alt ist die Spiegel-Kopie	so oft schaut der Zugriffs-Wächter nach fremden Geräten	Passwörter oder Geheimschlüssel im App-Programm (automatisch geprüft)

Ampel: Wie gut ist was geschützt?

● Gut geschützt	Zugang (Link/Code), Datenbank, Rechte, Sicherungen, Wiederherstellung, Wächter, geheime Abstimmungen
● Gut – mit deiner Mithilfe	Dein Handy: Bildschirmsperre benutzen, Link nicht weitergeben, vor dem Weitergeben des Geräts abmelden
● Bewusste Grenze	Chat ist nicht Ende-zu-Ende-verschlüsselt (siehe Seite 10 „Ehrlich gesagt")

So hängt alles zusammen

Wer schiebt welche Daten wohin? Die Pfeile zeigen den Weg. Das Wichtigste: **Alle Wege laufen durch den Club-Server** – er ist der Türsteher.



Wer schiebt was?

- **Du** schickst Zusagen, Nachrichten, Fotos, deinen Status und Änderungsmeldungen.
- **Die Clubleitung** trägt Termine, Mitgliederdaten und gemeldete Änderungen ein.
- **Der Club-Server** prüft und speichert – sonst nichts.
- **Die Automatik** legt nachts und alle 6 Stunden die Kopien an. Dabei greift kein Mensch ein.

Was bekommt wer?

- **GitHub** liefert nur das App-Programm aus – es sieht keine Mitgliederdaten.
- **Push / E-Mail** bekommt nur den Hinweis, dass es etwas Neues gibt.
- **Cloudflare** hält eine signierte Lesekopie für den Notbetrieb und verschlüsselte Notfall-Kopien.
- **Fremde** bekommen nichts. Der Spiegel enthält Personendaten nur gekürzt.

Wer kann welche Daten sehen?

Aufteilung nach Art der Daten. „Clubleitung“ sind Clubsprecher und Kassenwart (Ämter).

Daten	Du selbst	Andere Mitglieder	Clubleitung
Name, Bild, Status (z. B. „im Urlaub“)	✔ ja	✔ ja	✔ ja
Handy, Festnetz, E-Mail, Adresse	✔ ja	◐ nur, wenn du es erlaubst	✔ ja
Geburtstag	✔ ja	◐ nur Tag + Monat, wenn erlaubt	◐ Alter nur bei runden Geburtstagen, wenn erlaubt
Notfallkontakt	✔ ja	✘ nein	◐ Clubsprecher + Kassenwart
Notfallpass (Allergien, Medikamente)	◐ nur auf deinem Handy	✘ nein	✘ nein
Chat-Nachrichten und Anhänge	✔ ja	◐ nur Teilnehmer der Unterhaltung	◐ nur, wenn sie Teilnehmer sind
Fotoalbum	✔ ja	◐ Club-Album: ja · privates Album: nein	◐ Club-Album: ja · privates Album: nein
Zu-/Absage zu Terminen	✔ ja	✔ ja	✔ ja
Eigene Dienstzeiten	✔ ja	◐ nur mit deiner Freigabe (Standard: aus)	✔ ja
Online / zuletzt da / Tippen	✔ ja	◐ nur, wenn eingeschaltet	◐ wie Mitglieder
Wie du geheim abgestimmt hast	◐ nur, dass du abgestimmt hast	✘ nein	✘ nein
Bankverbindung (zurzeit nicht abgefragt)	✔ ja	✘ nein	◐ nur Kassenwart

Geheime Abstimmung – wirklich geheim: Die Stimme wird **ohne deinen Namen** gespeichert, mit einer zufälligen Nummer, damit man nicht einmal die Reihenfolge ablesen kann. Gemerkt wird nur, *dass* du abgestimmt hast – nicht *wie*.

Selbst prüfen: Unter *Einstellungen → Privatsphäre* stellst du alles ein. Mit „So sehen mich die anderen“ siehst du sofort das Ergebnis. Die Kachel „Meine Daten“ zeigt dir, was über dich gespeichert ist – nur dir.

Sicherheit auf deinem Handy

Was liegt auf dem Gerät – und wie schützt du es?

Was auf dem Handy liegt

- dein persönlicher Zugangs-Schlüssel (damit du nicht jedes Mal den Link brauchst)
- Einstellungen: Ansicht, Farben, Schriftgröße, Kacheln
- Entwürfe, die du noch nicht abgeschickt hast
- dein **Notfallpass** (Allergien, Medikamente, Blutgruppe) – freiwillig und **nur** auf diesem Handy, er geht nie an den Server
- ein Zwischenspeicher für schnelles Laden

Was NICHT auf dem Handy liegt

- keine Passwörter oder Geheimschlüssel des Clubs
- keine Daten anderer Mitglieder, die du nicht sehen darfst – der Server schickt sie gar nicht erst
- kein Cookie: der Schlüssel geht nicht bei jedem Seitenaufruf mit

Wenn etwas passiert

1. **Handy weitergeben oder verkaufen:** vorher unter *Einstellungen → Privatsphäre* auf „Von diesem Gerät abmelden“ tippen. Dann sind Zugang und alle Club-Daten auf dem Gerät gelöscht – auch Notfallpass und Entwürfe.
2. **Handy verloren oder gestohlen:** auf einem anderen Gerät „Alle anderen Geräte abmelden“ wählen – oder dem Admin Bescheid geben. Der alte Schlüssel gilt dann sofort nicht mehr.
3. **Neues Gerät:** Meldet sich jemand mit deinem Zugang auf einem neuen Gerät an, bekommst du eine Nachricht. Warst du es nicht, meldest du es mit einem Tipp – alle anderen Geräte sind dann abgemeldet.
4. **Link verloren:** Auf der Anmeldeseite „Link verloren“ – ein neuer Link kommt per E-Mail. Der alte gilt danach nicht mehr.

Deine Mithilfe: Bildschirmsperre (PIN, Fingerabdruck, Gesicht) einschalten · Handy-Updates installieren · den persönlichen Link nie weitergeben – wer ihn hat, ist in der App als du angemeldet.

Schutz vor falschen Links: Die App prüft Links in Nachrichten und warnt bei Doppelgänger-Adressen, Kurz-Links, Adressen mit „@“-Trick oder Seiten, die nach Passwörtern fragen.

Wie sicher sind die Zugangsdaten?

Kein Passwort, das man vergessen oder erraten kann – sondern ein langer, zufälliger persönlicher Schlüssel.

So funktioniert dein Zugang

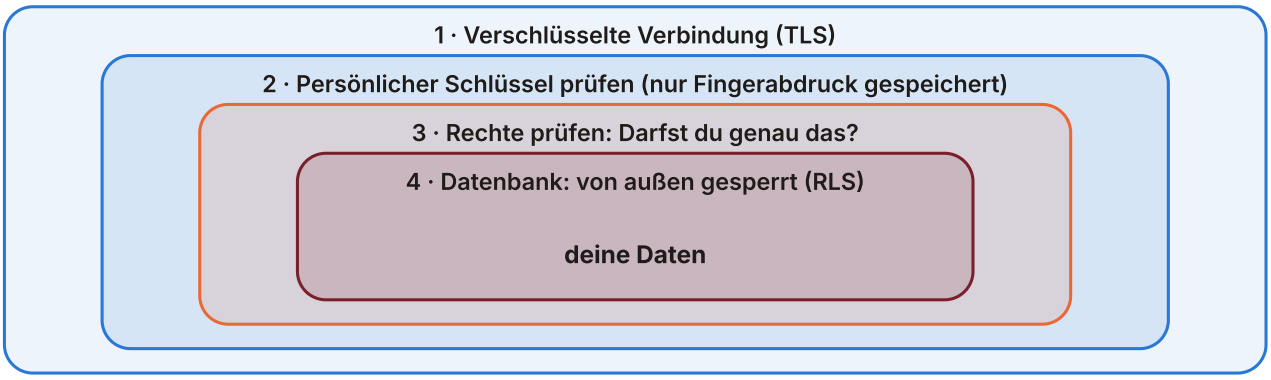
- Der Admin erzeugt dir einen **persönlichen Link**. Darin steckt ein langer Zufallsschlüssel.
- Beim ersten Öffnen wird der Schlüssel **sofort aus der Adresszeile entfernt**.
- Der Server speichert nur den **Fingerabdruck** (SHA-256). Aus dem Fingerabdruck lässt sich der Schlüssel nicht zurückrechnen.
- Für ein zweites Gerät gibt es einen **6-stelligen Code**, der nur kurz gilt.

So wird aufgepasst

- **Fremde Anmeldeversuche** werden protokolliert (90 Tage). Ab 5 Fehlversuchen in 15 Minuten – oder sofort bei Programmen/Bots – bekommt der Admin eine Meldung.
- **Sicherheits-Wächter:** bremst ungewöhnlich viele Abrufe („Absaugen“) und Abtast-Versuche.
- **Alte Links aufräumen:** Links, die 21 Tage nie benutzt wurden oder 60 Tage ruhen, schlägt die App zum Abschalten vor.
- Geheimnisse werden „in gleichbleibender Zeit“ verglichen – so kann niemand über die Antwortzeit raten.

Schutzschichten bis zu deinen Daten

Wer an deine Daten will, muss an allen Stufen vorbei. Jede Stufe für sich hält einen Angreifer auf.



Server-Funktionen mit Zugang von außen

Sicherheitsprüfung aller Datenbank-Funktionen am 23.10.2026 – jede einzeln angesehen.



- **35** prüfen die Anmeldung selbst – in Ordnung
- **2** ohne Anmeldung nötig, durch Geheim-Schlüssel geschützt
- **5** alte Umfrage-/Dankesfunktionen – werden abgeschaltet

Wie sicher ist die Datenbank?

Die Datenbank ist das Original. Sie steht bei Supabase in London – Großbritannien gilt nach EU-Recht als sicheres Land mit gleichwertigem Datenschutz.

Schutz in der Datenbank

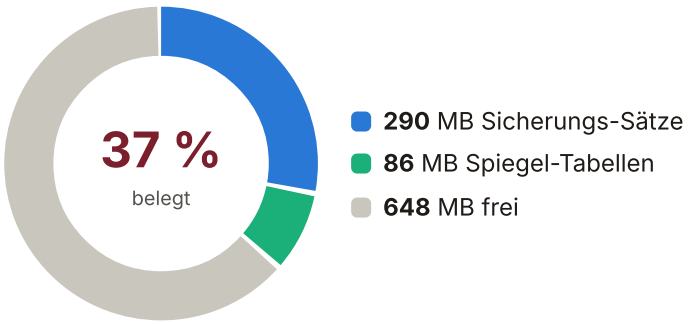
- **Tür zu für alle:** Bei jeder Club-Tabelle ist die Zugriffssperre (RLS) eingeschaltet. Von außen darf niemand lesen – nur der Club-Server.
- **Neue Tabellen** bekommen keine Rechte von selbst; ein automatischer Test verhindert Fehler.
- **Verschlüsselt gespeichert** auf den Festplatten des Anbieters.
- **Fotos und Anhänge** liegen in einem geschlossenen Speicher und werden nur mit Links geöffnet, die nach kurzer Zeit (höchstens 1 Stunde) verfallen.

Wächter rund um die Uhr

- **Zugriffs-Wächter** (jede Minute): meldet neue Geräte, neue Konten und gehäufte Anmeldungen per Push und E-Mail.
- **Geheimnis-Wächter:** Vor jedem Update wird automatisch geprüft, dass kein Passwort oder Schlüssel ins Programm gerutscht ist.
- **Geheimnisse** des Servers liegen nur im Tresor (Vault) des Anbieters – nie im Programm, nie im Browser.
- Kritische Arbeiten nur nach Plan: *Analyse → Auswirkung → Sicherungspunkt → Freigabe → Ausführung → Prüfung → Protokoll*.

Speicher des Spiegels und der Sicherungen (Neon, kostenloser Tarif)

Stand 20.10.2026 – von 1.024 MB sind 376 MB belegt. Es ist reichlich Platz, die Sicherungen laufen nicht in Gefahr.



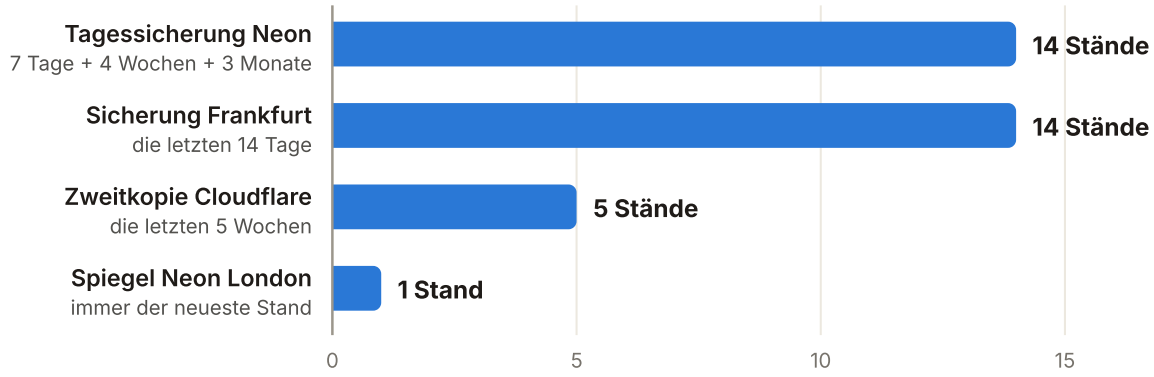
Kein Single Point of Failure: Fällt die Datenbank aus, schaltet die App nach zwei Fehlversuchen auf den **Notbetrieb** (orangenes Band): Du kannst weiter lesen, Nachrichten in bestehenden Chats schreiben, zu- oder absagen. Alles wird später genau einmal nachgetragen – nichts geht still verloren.

Spiegelung und Sicherung (Backup)

Ein **Spiegel** ist eine laufend aktualisierte Kopie zum Nachsehen. Eine **Sicherung** ist ein eingefrorener, verschlüsselter Stand von einem bestimmten Tag – zum Zurückholen.

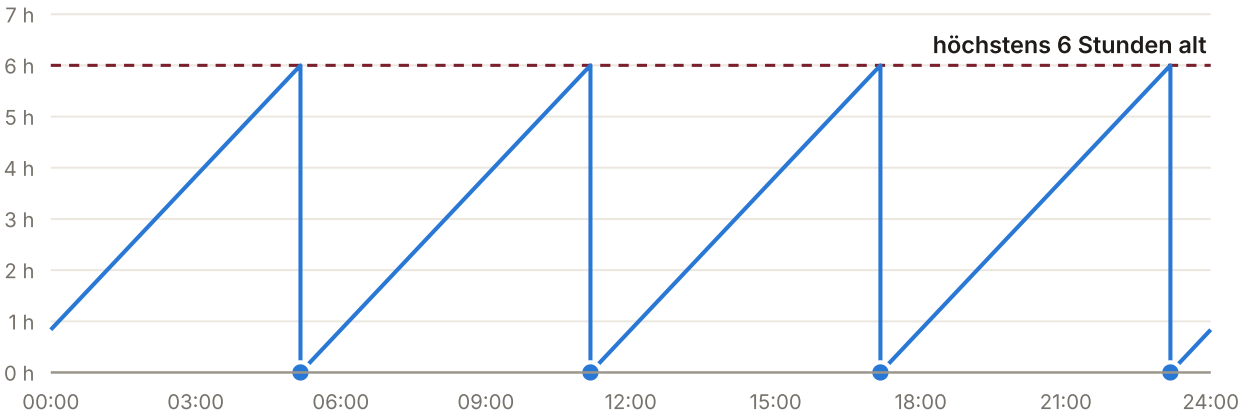
Wie viele Sicherungsstände werden aufbewahrt?

Drei getrennte Orte. Selbst wenn einer ganz ausfällt, sind die anderen da.



Wie alt ist die Spiegel-Kopie?

Alle 6 Stunden – um 5:10, 11:10, 17:10 und 23:10 Uhr – wird der Spiegel aufgefrischt. Er ist also nie älter als 6 Stunden.



Uhrzeit (deutsche Winterzeit) · Punkt = neue Kopie fertig

Verschlüsselt

Alle Sicherungen sind mit AES-256 verschlüsselt (gilt als nicht knackbar). Ohne den Schlüssel sind sie nur Zeichensalat.

Unveränderlich

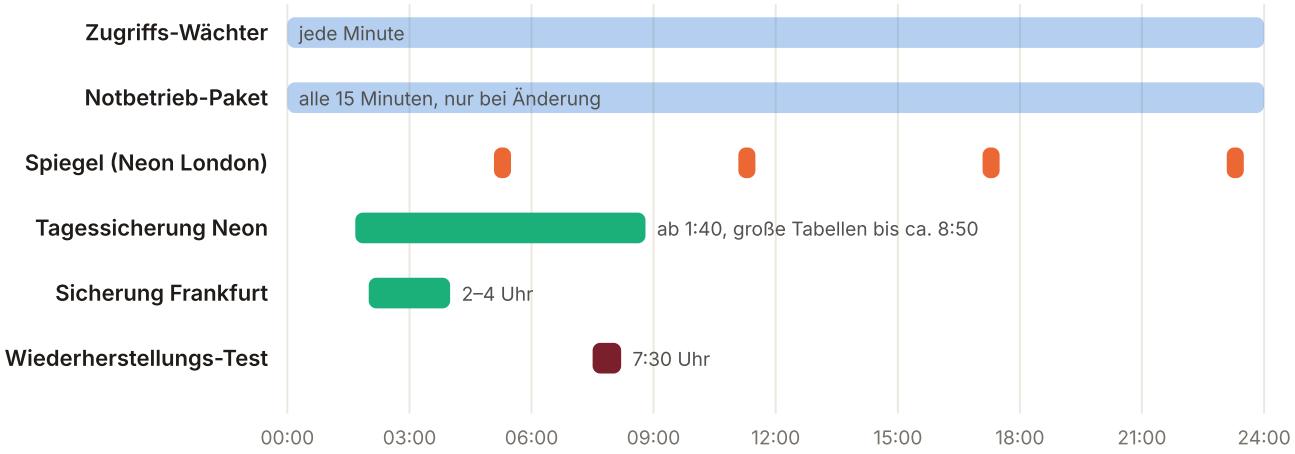
Die Tagessicherungen sind gegen Ändern und Löschen gesperrt. Nur die Aufräum-Regel darf alte Stände entfernen.

Ein Tag Datensicherheit

Was die Automatik jeden Tag macht – ohne dass jemand daran denken muss (deutsche Winterzeit).

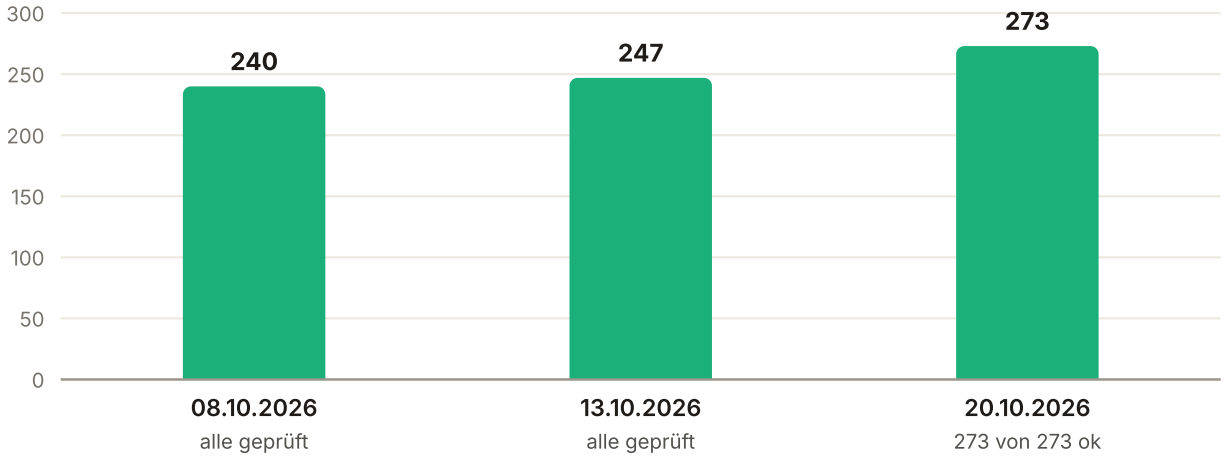
Zeitplan der Schutz-Aufgaben

Die Sicherungen laufen nachts, wenn kaum jemand die App benutzt.



Wiederherstellungs-Test: Tabellen gesichert und geprüft

Jeden Morgen wird die neueste Sicherung entschlüsselt und Tabelle für Tabelle mit der Prüfsumme verglichen. Die Zahl wächst, weil die App neue Bereiche bekommt.



Zusätzlich jede Woche: Sonntags holt ein Prüf-Ablauf eine zufällige Tabelle aus der Sicherung und entschlüsselt sie **ganz ohne Supabase** – mit der Schlüssel-Kopie aus dem Tresor. Montags wird die Zweitkopie bei Cloudflare angelegt, zurückgelesen und geprüft. So ist jede Woche bewiesen: Die Daten sind auch im schlimmsten Fall wieder herstellbar.

Regelmäßig von KI überprüft

Unser Admin lässt die **gesamte App** regelmäßig mit künstlicher Intelligenz überprüfen – mit **Claude Code** und **ChatGPT**. Vier Augen sehen mehr als zwei, und zwei verschiedene KI-Prüfer finden mehr als einer.

🛡️ Sicherheit

Wo könnte jemand eindringen? Sind alle Türen zu? Liegt irgendwo ein Passwort, wo es nicht hingehört?

🔍 Sicherheitslücken

Jede Server-Funktion wird einzeln gelesen: Prüft sie selbst, wer anfragt? Lässt sie nur das Erlaubte durch?

👆 Bedienkonzept

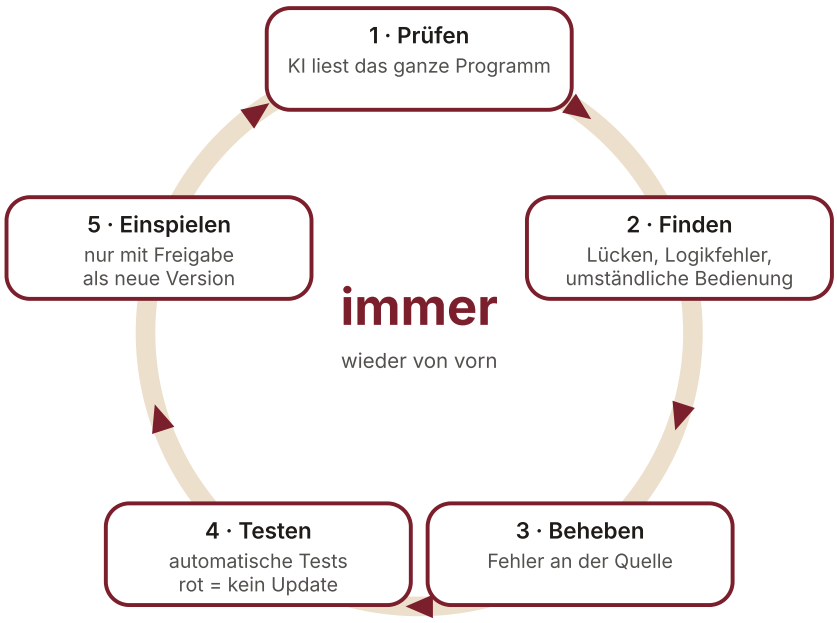
Ist alles einfach und verständlich? Findet man sich zurecht – auch mit großer Schrift und ohne Technikwissen?

🧠 Logik

Rechnet und entscheidet die App richtig? Passen Termine, Dienstpläne, Abstimmungen und Benachrichtigungen zusammen?

Der Prüf-Kreislauf

Jede gefundene Schwachstelle durchläuft diese Schritte – erst danach kommt ein Update zu dir.



Beispiele aus diesem Monat

- **13.10.2026:** Quelltext aller 85 Server-Funktionen auf Lücken geprüft.
- **23.10.2026:** alle 42 Datenbank-Funktionen mit Zugang von außen einzeln geprüft.
- **23.10.2026:** alle Club-Programme samt Verlauf nach Passwörtern und Schlüsseln durchsucht – nichts gefunden.

Klare Regeln für die KI

- Die KI bekommt **keine Passwörter oder Schlüssel**.
- Sie schlägt vor – **entscheiden und freigeben** tut immer ein Mensch.
- Vor jedem Update laufen **automatische Tests**; ein roter Test stoppt das Update.

Datenschutz-Grundverordnung (DSGVO)

Deine Rechte – und wo du sie in der App findest.

Art. 15	**Auskunft**	Kachel „Meine Daten“ zeigt alles, was über dich gespeichert ist – jederzeit, ohne Antrag.
Art. 16	**Berichtigung**	„Meine Daten haben sich geändert“: Meldung geht automatisch an die zuständigen Ämter.
Art. 17	**Löschung**	Austritt oder Löschwunsch über die Änderungsmeldung bzw. bei der Clubleitung; der Zugang wird abgeschaltet.
Art. 20	**Daten mitnehmen**	„Meine Daten“ lässt sich ausdrucken oder als Datei sichern.
Art. 21	**Widerspruch**	Sichtbarkeit von Kontakt, Geburtstag, Online-Status, Dienstzeiten selbst ausschalten.
Art. 25	**Datenschutz durch Voreinstellung**	Heikle Schalter stehen ab Werk auf AUS (z. B. Live-Tippen, Dienstzeiten für andere).
Art. 5	**Datensparsamkeit**	Spiegel enthält Personendaten nur gekürzt; Bankverbindung wird zurzeit gar nicht abgefragt.
Art. 32	**Sicherheit der Verarbeitung**	Verschlüsselte Übertragung und Speicherung, Rechteprüfung bei jeder Anfrage, Sicherungen mit täglichem Test.
Art. 33	**Pannen erkennen und melden**	Wächter melden neue Geräte, neue Konten und Angriffsversuche sofort an den Admin.

Ehrlich gesagt – die Grenzen

- **Keine Ende-zu-Ende-Verschlüsselung im Chat.** Nachrichten sind unterwegs und gespeichert verschlüsselt, aber nicht so, dass nur Absender und Empfänger sie lesen könnten. Für sehr Persönliches lieber ein Telefonat.
- **Wer den Link hat, ist du.** Deshalb nie weitergeben – und bei Verlust sofort melden.
- **Anbieter in der Cloud:** Supabase, Neon, Cloudflare, GitHub und der Anruf-Vermittler (für Telefonate/Video) sind Dienstleister. Sie bekommen nur, was sie für ihre Aufgabe brauchen; Sicherungen erhalten sie nur verschlüsselt.
- **Kein Schutz ist 100 %.** Darum gibt es mehrere Schichten, Wächter und geprüfte Sicherungen.

Was du selbst tun kannst

🔐 Bildschirmsperre am Handy einschalten

🔗 Persönlichen Link nie weitergeben

⚙️ Privatsphäre-Schalter einmal ansehen

🚪 Vor dem Weitergeben des Handys abmelden

Fragen zum Datenschutz? Wende dich an die Clubleitung oder den Admin in der App. Diese Übersicht beschreibt den technischen Stand vom 29.10.2026 und ersetzt nicht die Datenschutzerklärung des Vereins.